

Security+ 2.3 · Cross-Site Scripting (XSS)

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.3 — Cross-Site Scripting (XSS) (8:34) · [vídeo original ↗](#) · [YouTube ↗](#)

Injeta JavaScript num site de terceiros que roda COM AS CREDENCIAIS DA VÍTIMA (cookie, sessão). 3 tipos: Refletido (no link — vítima clica), Persistido (fica no DB — afeta todos que ver), DOM-based. Defesa: sanitize/escape output, HttpOnly cookie, CSP (Content Security Policy).

💡 Highlights que a prova cobra

- XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA
- Persistido = armazenado no banco; refletido = vem do query string
- HttpOnly cookie: JavaScript não pode ler — mitiga XSS stealing

🎯 Dicas de prova

- 'malicious JavaScript runs in the victim's browser' = XSS
- 'Content Security Policy as defense' = XSS mitigation

Cenário clássico: Cenário: 'comentário malicioso num fórum executa script em quem vê o comentário' = XSS persistido.

✅ Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Injetar script malicioso numa página pra rodar no navegador de OUTROS usuários:

- A) XSS (Cross-Site Scripting)
- B) CSRF
- C) SQLi
- D) Buffer overflow

2. Qual dispositivo de segurança de rede opera na camada de aplicação (Layer 7) e pode inspecionar conteúdo HTTP/HTTPS?

- A)** Firewall stateful tradicional
- B)** Web Application Firewall (WAF)
- C)** Switch Layer 2
- D)** Hub

3. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA...

4. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Persistido = armazenado no banco; refletido = vem do query string'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Persistido = armazenado no banco; refletido = vem do query string...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'HttpOnly cookie: JavaScript não pode ler — mitiga XSS stealing'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: HttpOnly cookie: JavaScript não pode ler — mitiga XSS stealing...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'malicious JavaScript runs in the victim's browser' = XSS'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'malicious JavaScript runs in the victim's browser' = XSS...

7. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Content Security Policy as defense' = XSS mitigation'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'Content Security Policy as defense' = XSS mitigation...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Cenário: 'comentário malicioso num fórum executa script em quem vê o comentário' = XSS persistido.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Cenário: 'comentário malicioso num fórum executa script em quem vê o coment...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Persistido = armazenado no banco; refletido = vem do query string'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Persistido = armazenado no banco; refletido = vem do query string...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

- 1) A — XSS (Cross-Site Scripting).** XSS injeta JavaScript que roda no navegador da vítima. Defesa: sanitizar/escapar a saída. SQLi ataca o banco; CSRF força ação autenticada.
- 2) B — Web Application Firewall (WAF).** WAF opera na camada 7 do modelo OSI, inspecionando tráfego HTTP/HTTPS para proteger aplicações web contra ataques como SQL injection e XSS.
- 3) D — Implementar a solução correspondente: XSS roda JavaScript no navegador da VÍTIMA.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA. As demais alternativas configuram violaç
- 4) B — Implementar a solução correspondente: Persistido = armazenado no banco; refletid.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): Persistido = armazenado no banco; refletido = vem do query string. As demais alternativas configuram viola
- 5) C — Implementar a solução correspondente: HttpOnly cookie: JavaScript não pode ler —.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): HttpOnly cookie: JavaScript não pode ler — mitiga XSS stealing. As demais alternativas configuram violação
- 6) D — Implementar a solução correspondente: 'malicious JavaScript runs in the victim's.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): 'malicious JavaScript runs in the victim's browser' = XSS. As demais alternativas configuram violações gra
- 7) B — Implementar a solução correspondente: 'Content Security Policy as defense' = XSS.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): 'Content Security Policy as defense' = XSS mitigation. As demais alternativas configuram violações graves
- 8) A — Implementar a solução correspondente: Cenário: 'comentário malicioso num fórum e.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): Cenário: 'comentário malicioso num fórum executa script em quem vê o comentário' = XSS persistido.. As dem
- 9) A — Implementar a solução correspondente: XSS roda JavaScript no navegador da VÍTIMA.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA. As demais alternativas configuram violaç
- 10) C — Implementar a solução correspondente: Persistido = armazenado no banco; refletid.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): Persistido = armazenado no banco; refletido = vem do query string. As demais alternativas configuram viola

